CISM engagement report — 172.28.0.3/login.php

- Run: `d7a3f96e226c40a78c001117f368a42c`
- Generated: 2026-10-19T01:28:35+00:00
- Outcome: completed — 1 tool call(s), 0 failure(s), 0 guardrail block(s)

Phase progression

- `2026-10-19T01:22:54+00:00` → **recon**
- `2026-10-19T01:26:38+00:00` → **enumeration**
- `2026-10-19T01:27:10+00:00` → **vulnerability-discovery**
- `2026-10-19T01:27:43+00:00` → **exploitation**

Findings

[resolved] curl — 172.28.0.3/login.php (4ec947258b6c)

- `01:26:06` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] open-port — 172.28.0.3/login.php (443/tcp)

- `01:26:37` **curl** [T3]: Open HTTP port 443/tcp is exploitable.

[resolved] open-port — 172.28.0.3/login.php (80/tcp)

- `01:26:37` **curl** [T3]: Open HTTP port 8443/tcp is exploitable.

[resolved] open-port — 172.28.0.3/login.php (8443/tcp)

- `01:26:37` **curl** [T3]: Open HTTP port 8443/tcp is exploitable.

[resolved] open-port — 172.28.0.3/login.php (Apache/2.4.25 (Debian))

- `01:27:08` **curl** [T3]: Server header reveals an outdated Apache version.

[resolved] open-port — 172.28.0.3/login.php (Apache/2.4.25 (Debain))

- `01:27:08` **curl** [T2]: Server header reveals an outdated Apache version.

[resolved] open-port — 172.28.0.3/vulnerabilities/sqli/?id=1'%20union%20select%20user,password%20from%20users--+-&submit=submit (Apache/2.4.25 (Debian))

- `01:27:41` **curl** [T3]: Server header reveals Apache 2.4.25 on Debian.

[resolved] session-hijacking — 172.28.0.3/vulnerabilities/sqli/?id=1'%20union%20select%20user,password%20from%20users--+-&submit=submit (PHPSESSID cookie without HttpOnly flag)

- `01:27:41` **curl** [T2]: Session cookie lacks HttpOnly flag, vulnerable to XSS-based session hijacking.

[resolved] sql-injection — 172.28.0.3/vulnerabilities/sqli/?id=1'%20union%20select%20user,password%20from%20users--+-&submit=submit (SQL Injection)

- `01:28:13` **curl** [T1]: SQL injection demonstrated via UNION SELECT leaking user/password rows from the users table.

[resolved] blind-sql-injection — 172.28.0.3/vulnerabilities/sqli/?id=1'%20union%20select%20user,password%20from%20users--+-&submit=submit (SQL Injection (Blind))

- `01:28:13` **curl** [T1]: Blind SQL injection menu entry present in the navigation.

[resolved] file-inclusion — 172.28.0.3/vulnerabilities/sqli/?id=1'%20union%20select%20user,password%20from%20users--+-&submit=submit (File Inclusion)

- `01:28:13` **curl** [T3]: File inclusion menu entry present in the navigation.

Narrative context

- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (recon) I'll help with this DVWA security testing exercise. Let me start by GETting the login page with headers to capture the s
- `[T3]` (recon) Open HTTP port 443/tcp is exploitable.
- `[T3]` (recon) Open HTTP port 8443/tcp is exploitable.
- `[T3]` (recon) Open HTTP port 8443/tcp is exploitable.
- `[T3]` (recon) POSTing the login credentials now.
- `[T2]` (recon) phase proposal → enumeration (pending /phase approval)
- `[T3]` (enumeration) Server header reveals an outdated Apache version.
- `[T2]` (enumeration) Server header reveals an outdated Apache version.
- `[T3]` (enumeration) POSTing the login credentials now, with headers visible to confirm the redirect.
- `[T2]` (enumeration) phase proposal → vulnerability-discovery (pending /phase approval)
- `[T3]` (vulnerability-discovery) Server header reveals Apache 2.4.25 on Debian.
- `[T2]` (vulnerability-discovery) Session cookie lacks HttpOnly flag, vulnerable to XSS-based session hijacking.
- `[T2]` (vulnerability-discovery) phase proposal → exploitation (pending /phase approval)
- `[T1]` (exploitation) SQL injection demonstrated via UNION SELECT leaking user/password rows from the users table.
- `[T1]` (exploitation) Blind SQL injection menu entry present in the navigation.
- `[T3]` (exploitation) File inclusion menu entry present in the navigation.
- `[T3]` (exploitation) Retrying the SQLi URL with the authenticated session cookie.